École Supérieure des Communications de Tunis
SUP'COM

Tessera

Plateforme intelligente de billetterie numérique

Anti-contrefaçon, anti-truquage et anti-scalping

RECUEIL DES BESOINS

Besoins fonctionnels et exigences de sécurité (SRE, Shift-Left)

Réalisé par :
Mohamed Fourat Boujdaria
Brahim Cheikh

Enseignant : Dr. Ing. Mohamed-Becha Kaâniche
Classe : INDP3 CySeD
Année Universitaire : 2026–2027

Présentation du document

Ce recueil rassemble les **besoins fonctionnels** et les **exigences de sécurité** de la plateforme Tessera. Il complète le cahier des charges déposé dans le même dépôt : il en reprend les identifiants (`F-xx`, `NF-xx`) et les précise par des critères d'acceptation vérifiables. Il **justifie l'approche d'ingénierie des exigences de sécurité (SRE) retenue**, une seule, les *cas d'abus* (section 3), puis recense en détail 57 exigences de sécurité déclinées sur la pile technique du projet (PWA/SPA, Jakarta EE 11, WildFly 42, Java 25) et rattachées au flux métier de billetterie (section 5). Le document est vivant : il évolue avec le cours (section 7.4).

Historique des versions

Version	Date	Nature de la modification	Auteurs
1.0	10/11/2026	Premier jet, remplacé : combinait trois approches (STRIDE, cas d'abus, catalogue de contrôles).	Équipe 8
2.0	11/11/2026	Refonte : **une seule approche** (cas d'abus) justifiée ; 14 cas d'abus ; 57 exigences par type de sécurité, par couche de la pile et par fonction du cahier des charges ; matrices de traçabilité et planification par semaine.	Équipe 8

Sommaire

Présentation du document **1**

1 Cadre et périmètre **3**
1.1 Objet du document . . . 3
1.2 Documents de référence . . . 3
1.3 Périmètre . . . 3
1.4 Hypothèses de menace . . . 3
1.5 Actifs à protéger . . . 4
1.6 Adversaires . . . 4

2 Besoins fonctionnels **4**
2.1 Fonctions et critères d'acceptation . . . 4
2.2 Cycle de vie du billet . . . 6
2.3 Exigences non fonctionnelles et sécurité . . . 7

3 Justification de l'approche SRE choisie **7**
3.1 Ce que le cours impose . . . 7
3.2 Approche retenue : les cas d'abus . . . 7
3.3 Pourquoi les cas d'abus pour Tessera . . . 8
3.4 Comparaison avec les autres méthodologies du cours . . . 8
3.5 Mise en œuvre : de l'abus à l'exigence . . . 8
3.6 Conventions . . . 9

4 Cas d'abus **9**
4.1 Synthèse . . . 9
4.2 Fiches détaillées . . . 10

5 Exigences de sécurité **14**
5.1 Organisation . . . 14
5.2 Identification et authentification . . . 15
5.3 Autorisation (contrôle d'accès) . . . 17
5.4 Intégrité et confidentialité des données . . . 18
5.5 Non-répudiation . . . 20
5.6 Détection d'intrusions et audit . . . 20
5.7 Résilience et disponibilité . . . 21

6 Traçabilité et vérification **23**
6.1 Matrice cas d'abus et exigences . . . 23
6.2 Planification par semaine et par chapitre . . . 24
6.3 Stratégie de vérification . . . 24
6.4 Portes de sécurité CI/CD . . . 24

7 Limites, risques résiduels et évolution **25**
7.1 Limites explicites . . . 25
7.2 Risques résiduels . . . 25
7.3 Effet de l'ordre de coupe du cahier des charges . . . 26
7.4 Gestion des exigences et évolution . . . 26

Références **26**

Annexe A — Glossaire **27**

1 Cadre et périmètre

1.1 Objet du document

Le cours demande une démarche *Shift-Left* : les exigences de sécurité sont écrites avant le code, du point de vue de l'attaquant, en visant les trois propriétés de confidentialité, d'intégrité et de disponibilité (C-I-D), sous forme d'exigences précises et propres au système plutôt que de listes génériques. Ce recueil applique ces consignes à Tessera, plateforme PWA/SPA de billetterie de grands événements dont la singularité est l'application de trois mécanismes de dissimulation de l'information (filigrane, empreinte, sceau stéganographique) au visuel du billet.

1.2 Documents de référence

— **Cahier des charges de Tessera** (même dépôt, répertoire `/docs`) : fonctions `F-01` à `F-15`, exigences non fonctionnelles `NF-01` à `NF-08`, rôles, zones de confiance `Z0` à `Z6`, cycle de vie du billet, planning.

— Supports du cours *Sécurité applicative* (chapitres 2 à 7) ; courriel de l'enseignant sur les objectifs du recueil des besoins.

— Spécifications Jakarta EE 11, WildFly 42 et Java 25 ; RFC citées en références.

1.3 Périmètre

Dans le périmètre : la PWA/SPA, l'API REST Jakarta EE 11 sur WildFly 42 (Java 25), la persistance PostgreSQL, le moteur de marquage d'images, le terminal de scan (PWA) et le déploiement par conteneurs. **Hors périmètre** (cahier des charges, §3.1) : paiement réel, place de marché secondaire, application mobile native, contrôle hors ligne, résistance à la collusion et aux attaques agressives sur les marques. Ces limites sont traitées comme des risques résiduels explicites (section 7).

1.4 Hypothèses de menace

Réf.	Hypothèse
H-01	Le navigateur, le terminal de l'utilisateur et les images téléchargées sont contrôlables par un attaquant : aucune décision de sécurité n'est prise côté client (zone `Z0`).
H-02	Un attaquant peut créer plusieurs comptes, automatiser des requêtes, rejouer des messages, copier des captures d'écran et modifier des pixels.
H-03	Un utilisateur légitime peut partager volontairement ou non son billet.
H-04	Un compte privilégié (organisateur, auditeur, administrateur) peut être compromis ou curieux : séparation des pouvoirs et journalisation sont donc nécessaires.
H-05	Le prestataire de paiement est un tiers de confiance limitée : sa notification doit être authentifiée et idempotente.
H-06	Les clés privées et de chiffrement ne sont jamais accessibles au front-end ; le réseau est observable (TLS obligatoire).
H-07	L'hôte d'exécution des conteneurs et le noyau ne sont pas compromis (hors périmètre).

1.5 Actifs à protéger

Actif	CIA	Zone de confiance (cahier des charges, §2.5.2)
Billets (état, affectation, claims signés)	I, D	Z3 Services métier, Z4 Données
Clés : signature Ed25519, chiffrement du sceau, marquage, webhook	C, I	Z5 Secrets
Table de correspondance empreinte–affectation	C	Z4 Données
Données des acheteurs et des organisateurs	C	Z4 Données
Journal d'audit et dossiers d'enquête	I	Z4 Données
Services de réservation, d'émission et de scan	D, I	Z2 API, Z3 Services métier
Sessions, jetons d'appareil, jetons de téléchargement	C, I	Z0 Client, Z2 API
Rendus de billets (PNG marqués)	I, C	Z4 Données

1.6 Adversaires

Cinq profils d'adversaires sont retenus ; ils servent de point de départ à la rédaction des cas d'abus (section 4).

Réf.	Adversaire	Capacités	Objectifs	Abus
A1	Attaquant externe ou automatisé (scalpeur)	Comptes multiples, scripts, rotation d'adresses IP, rejeu de requêtes, aucune habilitation au départ.	Accaparer le stock, prendre un compte, forger un paiement, saturer le service.	01, 06, 07, 10, 11, 14
A2	Acheteur malveillant ou faussaire	Compte et billet valides ; captures d'écran ; éditeur d'images ; connaissance de l'API.	Revendre ou dupliquer un billet, en fabriquer un, fuiter ou faire accuser un tiers.	02, 03, 04, 05, 07, 09
A3	Rôle privilégié curieux ou compromis	Droits d'organisateur, d'auditeur ou d'administrateur ; accès à la configuration ou aux journaux.	Espionner des acheteurs, effacer des traces, téléverser des images piégées, contourner la séparation des pouvoirs.	04, 05, 10, 11, 12, 13
A4	Agent ou terminal de scan compromis	Jeton d'appareil ou identifiants d'agent volés ; accès à l'endpoint de vérification.	Énumérer ou consommer des billets, agir hors affectation.	08, 14
A5	Attaquant de la chaîne d'approvisionnement ou du déploiement	Accès au dépôt, à une dépendance, à une image de conteneur ou à une sauvegarde.	Récupérer une clé, injecter du code, obtenir la main sur WildFly.	13

2 Besoins fonctionnels

2.1 Fonctions et critères d'acceptation

Les quinze fonctions du cahier des charges (§2.3) sont reprises avec un critère d'acceptation vérifiable et les exigences de sécurité qui les encadrent. Priorités MoSCoW : *Must* (noyau livré en priorité), *Should*, *Could*.

ID	Fonction	Prio.	Critère d'acceptation vérifiable	Exigences de sécurité
F-01	Gestion événement	Must	Un organisateur crée, modifie, publie et clôt un événement dont il est propriétaire ; le fond de billet (PNG $\leq$ 5 Mo, $\leq$ 16 Mpx) est accepté ou rejeté sans effet de bord ; l'événement d'un autre organisateur est inaccessible (404).	SEC-AZ-01, SEC-AZ-04, SEC-DC-07, SEC-DC-08, SEC-DC-09, SEC-RD-05, SEC-RD-06
F-02	Catalogue	Must	Un visiteur non authentifié liste les événements publiés (pagination, 50 éléments au plus), leurs disponibilités et leurs conditions de vente ; aucun événement non publié n'est visible.	SEC-AZ-01, SEC-AZ-08, SEC-DC-08, SEC-DC-09, SEC-DC-11, SEC-AU-06, SEC-RD-03
F-03	Réservation	Must	Un acheteur authentifié réserve au plus 4 billets par événement (quota configurable) ; la réservation expire en 10 min au plus ; le stock ne devient jamais négatif sous concurrence.	SEC-IA-01, SEC-IA-02, SEC-IA-04, SEC-IA-05, SEC-IA-09, SEC-AZ-01, SEC-DC-07, SEC-DC-11, SEC-AU-06, SEC-RD-03, SEC-RD-04
F-04	Paiement	Must	Le paiement est confirmé uniquement par la notification signée du prestataire (simulé en test) ; une notification répétée n'a aucun effet supplémentaire.	SEC-AZ-01, SEC-DC-14, SEC-NR-04
F-05	Émission	Must	Un billet n'est émis qu'après confirmation du paiement ; il porte un identifiant opaque, des claims signés Ed25519 et un jeton de scan ; une ligne de commande payée produit un seul billet.	SEC-DC-01, SEC-DC-02, SEC-DC-03, SEC-DC-12, SEC-DC-14, SEC-NR-01, SEC-NR-04
F-06	Personnalisation	Must	Le rendu PNG du billet porte le filigrane d'émetteur, l'empreinte de copie et le sceau chiffré/authentifié ; chaque exemplaire téléchargé reçoit une empreinte unique ; rendu produit en 10 s au plus.	SEC-DC-02, SEC-DC-04, SEC-DC-05, SEC-DC-06, SEC-DC-12, SEC-RD-07
F-07	Portefeuille	Must	L'acheteur liste, télécharge et présente uniquement ses billets actifs ; le lien de téléchargement est court-vécu.	SEC-IA-01, SEC-IA-02, SEC-IA-03, SEC-AZ-01, SEC-AZ-02, SEC-AZ-08, SEC-DC-09, SEC-DC-10, SEC-DC-11, SEC-DC-15
F-08	Transfert	Should	Le titulaire transfère un billet selon les règles de l'organisateur ; l'ancien billet est invalidé et le nouveau émis dans une même transaction.	SEC-IA-04, SEC-AZ-01, SEC-AZ-02, SEC-DC-07, SEC-NR-03, SEC-NR-05
F-09	Scan	Must	Un agent affecté vérifie un billet pour l'événement, la porte et le créneau autorisés ; décision serveur en moins de 500 ms (95e centile) ; réponse minimale.	SEC-IA-06, SEC-AZ-01, SEC-AZ-03, SEC-DC-01, SEC-DC-03, SEC-DC-11, SEC-NR-02, SEC-AU-06, SEC-RD-01, SEC-RD-02, SEC-RD-03, SEC-RD-08
F-10	Anti-rejeu	Must	La consommation d'un billet est atomique ; toute seconde présentation du même billet est refusée, y compris en concurrence.	SEC-NR-02, SEC-RD-01
F-11	Anti-fraude	Should	Le système signale les volumes anormaux, les tentatives répétées, les achats automatisés et les fuites identifiées (règles de vélocité simples).	SEC-IA-09, SEC-AZ-01, SEC-AU-05

ID	Fonction	Prio.	Critère d'acceptation vérifiable	Exigences de sécurité
F-12	Audit	Must	L'auditeur consulte les événements de sécurité filtrés par date, acteur, action et résultat ; aucun secret ni donnée personnelle en clair n'apparaît.	SEC-AZ-01, SEC-AZ-05, SEC-AZ-07, SEC-DC-13, SEC-AU-01, SEC-AU-02, SEC-AU-03, SEC-AU-04, SEC-AU-07
F-13	Administration	Must	L'administrateur gère comptes, rôles et configuration technique sans pouvoir modifier un billet consommé ni effacer l'audit.	SEC-IA-01, SEC-IA-02, SEC-IA-03, SEC-IA-07, SEC-IA-08, SEC-AZ-01, SEC-AZ-05, SEC-NR-03, SEC-RD-09, SEC-RD-10, SEC-RD-11, SEC-RD-12, SEC-RD-13
F-14	Révocation	Should	L'organisateur révoque un billet avec motif ; horodatage et auteur sont enregistrés ; le billet révoqué est refusé au scan.	SEC-AZ-01, SEC-AZ-04, SEC-AZ-05, SEC-NR-03
F-15	Analyse d'image	Must	L'auditeur soumet une image suspecte ($\leq$ 5 Mo, $\leq$ 16 Mpx) ; le serveur extrait et vérifie filigrane, empreinte et sceau, puis indique l'émetteur, l'exemplaire (sous habilitation) et l'état du sceau, ou « non concluant » ; réponse en 10 s au plus.	SEC-AZ-01, SEC-AZ-06, SEC-DC-05, SEC-DC-06, SEC-AU-07, SEC-RD-05, SEC-RD-06, SEC-RD-07

2.2 Cycle de vie du billet

Les exigences de sécurité s'appuient sur la machine à états du cahier des charges (§2.2.1). Toute transition est contrôlée par le domaine métier côté serveur et journalisée ; un billet `CONSUMED`, `REVOKED`, `EXPIRED` ou `TRANSFERRED` ne revient jamais à `ISSUED`.

État initial	Événement	État suivant
`RESERVED`	paiement confirmé	`ISSUED`
`RESERVED`	expiration ou échec	`EXPIRED`
`ISSUED`	scan valide atomique	`CONSUMED`
`ISSUED`	remboursement ou révocation	`REVOKED`
`ISSUED`	transfert validé	`TRANSFERRED`
`TRANSFERRED`	nouvel exemplaire émis	`ISSUED` (nouvel identifiant)

2.3 Exigences non fonctionnelles et sécurité

ID	Attribut	Cible du cahier des charges	Exigences de sécurité
NF-01	Performance scan	100 vérifications/s, 95 % des décisions en moins de 500 ms	SEC-RD-07, SEC-RD-08
NF-02	Disponibilité	Objectif de conception 99,5 % mensuel pour l'API de contrôle	SEC-RD-08, SEC-RD-09
NF-03	Concurrence	100 scans simultanés du même billet : un seul résultat d'admission positif	SEC-RD-01
NF-04	Résilience	Serveur de validation indisponible : pas d'accès accordé automatiquement	SEC-RD-02
NF-05	Traçabilité	Toute action privilégiée et toute décision de scan sont journalisées (UTC)	SEC-NR-02, SEC-NR-03, SEC-AU-01
NF-06	Compatibilité	PWA testée sur les deux dernières versions majeures des navigateurs mobiles ciblés	SEC-DC-10
NF-07	Accessibilité	Parcours d'achat et portefeuille utilisables au clavier et au lecteur d'écran (WCAG 2.2 AA)	*hors périmètre sécurité*
NF-08	Traitement d'image	Image $\leq$ 5 Mo et 16 Mpx ; marquage ou analyse en 10 s au plus ; rejet immédiat au-delà	SEC-RD-06, SEC-RD-07

3 Justification de l'approche SRE choisie

3.1 Ce que le cours impose

Le cours fixe quatre objectifs fondamentaux. Le tableau indique ce que chacun impose concrètement à Tessera et où le document y répond.

Objectif	Conséquence pour Tessera	Réponse du document
Shift-Left	Cas d'abus et exigences rédigés avant le code (semaine S0) ; chaque exigence *Must* a une vérification planifiée dans les semaines S1 à S4 du cahier des charges.	Sections 4 à 7.4 ; planification en section 6.2.
Perspective de l'attaquant	Chaque risque est décrit comme un scénario d'attaque de bout en bout (scalping, rejeu, contrefaçon, fuite) mené par un adversaire identifié.	Sections 1.6 et 4 : 14 cas d'abus.
Triptyque C-I-D	Chaque actif et chaque cas d'abus est étiqueté C, I ou D ; la disponibilité de l'API de scan à l'entrée est traitée comme un actif critique.	Tableaux des actifs et des cas d'abus.
Exigences précises, non génériques	Aucune exigence du type « utiliser des mots de passe » : chaque exigence nomme un mécanisme de la pile, une valeur mesurable et une vérification.	Section 5 : colonnes *Couche*, *Exigence mesurable*, *Vérification*.

3.2 Approche retenue : les cas d'abus

L'équipe retient **une seule approche** d'ingénierie des exigences de sécurité parmi celles du cours : les **cas d'abus** (*abuse cases*, ou cas de mésusage). Un cas d'abus est un cas d'utilisation inversé : il décrit ce qu'un adversaire tente de faire contre le système et que celui-ci ne doit pas permettre. À chaque cas d'abus répond le *cas d'utilisation de sécurité* correspondant, c'est-à-dire le comportement imposé au système, décliné en exigences `SEC-xx` mesurables et testables. Il s'agit du même formalisme, vu depuis l'attaquant puis depuis le système, et non d'une seconde méthode.

Une seule méthode, des notations simples

Aucune autre méthodologie du cours n'est appliquée. Les priorités MoSCoW et le niveau de risque (section 3.6) sont des notations de présentation et de tri, pas des méthodes d'analyse.

3.3 Pourquoi les cas d'abus pour Tessera

1. **Le risque de Tessera est un scénario métier.** Les menaces qui comptent (scalping, rejeu d'un billet capturé, contrefaçon, fuite d'un visuel, webhook de paiement forgé) sont des chaînes d'actions menées par un acteur du métier. Un cas d'abus les décrit telles quelles : attaquant, vecteur, déroulement, impact. Les exigences restent ainsi attachées aux fonctions `F-01` à `F-15` du cahier des charges, et non à une liste de contrôles détachée du produit.
2. **Un cas d'abus se décompose par couche de la pile.** Un même scénario traverse la PWA, l'API REST, Jakarta Security, la persistance, WildFly et le moteur d'images. On en tire une exigence par couche concernée, avec le mécanisme exact de cette couche (tableau 2). C'est ce qui rend les exigences précises et propres à Jakarta EE 11, WildFly 42, Java 25 et à la PWA.
3. **Un cas d'abus donne directement un test.** Chaque fiche se termine par un test d'abus automatisable ; chaque exigence porte sa vérification. La chaîne `AC-xx` → `SEC-xx` → chapitre du cours → test est complète et contrôlable : aucun cas d'abus sans exigence, aucune exigence sans cas d'abus.
4. **La méthode est proportionnée à un binôme et à la démarche Shift-Left.** Elle s'écrit en texte, se versionne dans le dépôt, se révise à chaque chapitre du cours et ne demande ni atelier avec des parties prenantes, ni outillage de modélisation.

3.4 Comparaison avec les autres méthodologies du cours

Méthodologie	Décision	Justification
Cas d'abus	**Retenue**	Voir ci-dessus.
SQUARE (9 étapes)	Non retenue	Processus complet avec arbitrage entre parties prenantes : disproportionné pour un binôme et quatre semaines de réalisation.
Récits d'abus et de sécurité	Non retenue	Extension agile qui suppose les abus déjà identifiés ; elle ne les produit pas. Les cas d'abus sont suivis comme tickets GitHub, sans rédiger de récits utilisateurs parallèles.
Arbres d'attaque et modélisation des menaces	Non retenue	Décomposent un objectif d'attaque à la fois ; ne produisent pas directement un ensemble d'exigences testables couvrant tout le système.
UMLsec, SecureUML	Non retenue	Supposent une chaîne d'ingénierie dirigée par les modèles, disproportionnée pour ce projet.
SERA	Non retenue	Orientée contextes opérationnels et chaînes de mission, peu adaptée à une application académique au périmètre réduit.
OCTAVE	Non retenue	Évaluation organisationnelle des risques et des actifs, trop lourde pour le projet.

3.5 Mise en œuvre : de l'abus à l'exigence

1. **Identifier** les actifs et les adversaires (sections 1, 1.6).
2. **Rédiger** les cas d'abus du point de vue de l'attaquant, un par scénario métier (section 4).
3. **Décider** pour chaque cas d'abus le cas d'utilisation de sécurité, puis le décomposer **par couche de la pile** en exigences `SEC-xx` mesurables, classées selon les six types du cours (section 5).

4. **Vérifier** : chaque exigence a un critère de test ; chaque cas d'abus a un test d'abus. Les tests sont marqués par l'identifiant de l'exigence (annotation JUnit `@Tag("SEC-AZ-02")`) pour que la couverture soit calculable.
5. **Maintenir** : toute évolution passe par une issue `requirement-change` (section 7.4).

TABLE 2 – Du cas d'abus à la pile : exemple de AC-02 (rejeu et double admission)

Couche de la pile	Décision issue de AC-02 (rejeu et double admission)	Exigences
PWA	Le QR ne porte qu'un jeton opaque ; le client ne décide jamais de l'admission ; aucun billet n'est conservé dans le cache.	SEC-DC-03, SEC-DC-10
API REST	Réponse minimale (admis ou refusé) ; refus de tout scan hors affectation.	SEC-AZ-03
Jakarta Security	Principal de l'agent et attributs d'affectation lus depuis le `SecurityContext`, jamais depuis le corps de la requête.	SEC-IA-02, SEC-IA-06
Persistance (JPA, PostgreSQL)	Consommation par mise à jour conditionnelle, exactement une ligne modifiée.	SEC-RD-01
WildFly (Undertow, pool JDBC)	Pool borné et limites de débit : 100 scans simultanés sans saturation.	SEC-RD-03, SEC-RD-08
Audit	Un événement d'audit exactement par requête de scan.	SEC-NR-02, SEC-AU-01

3.6 Conventions

— **Identifiants** : `AC-xx` cas d'abus ; `SEC-tt-nn` exigence de sécurité, où `tt` est le type : `IA` identification et authentification, `AZ` autorisation, `DC` intégrité et confidentialité des données, `NR` non-répudiation, `AU` détection d'intrusions et audit, `RD` résilience et disponibilité. Les identifiants ne sont jamais réutilisés.

— **Priorités MoSCoW** : *Must* (noyau livré en priorité), *Should*, *Could*.

— **Couche** : mécanisme de la pile qui porte l'exigence (PWA, API REST, Jakarta Security, JPA, PostgreSQL, Undertow, Elytron, Jakarta Concurrency, moteur d'images, JCA, Docker, CI/CD).

— **Niveau d'un cas d'abus** : probabilité et impact estimés qualitativement (faible, moyen, élevé), lus dans la matrice ci-dessous ; estimations révisées à chaque chapitre.

	Probabilité faible	**Probabilité moyenne**	**Probabilité élevée**
Impact élevé	Moyen	Élevé	**Critique**
Impact moyen	Faible	Moyen	Élevé
Impact faible	Note	Faible	Moyen

4 Cas d'abus

4.1 Synthèse

Les 14 cas d'abus ci-dessous couvrent les fonctions du cahier des charges et les six types d'exigences. Ils se répartissent en 2 de niveau critique, 11 de niveau élevé et 1 de niveau moyen. Le profil renvoie aux adversaires de la section 1.6.

ID	Cas d'abus	Profil	CIA	Niveau	Fonctions visées
AC-01	Scalping automatisé	A1	D, I	Élevé	F-03, F-08, F-11
AC-02	Rejeu et double admission d'un billet	A2	I	**Critique**	F-09, F-10
AC-03	Contrefaçon et altération du billet	A2	I	Élevé	F-05, F-06, F-09, F-15
AC-04	Accès à l'objet d'autrui (BOLA)	A2, A3	C, I	**Critique**	F-01, F-07, F-08
AC-05	Élévation de privilèges et séparation des pouvoirs	A2, A3	I, C	Élevé	F-12, F-13, F-14
AC-06	Prise de contrôle d'un compte	A1	C, I	Élevé	F-03, F-07, F-08, F-13
AC-07	Notification de paiement forgée ou rejouée	A1, A2	I	Élevé	F-04, F-05
AC-08	Terminal de scan ou compte agent compromis	A4	C, D	Moyen	F-09, F-10
AC-09	Fuite d'image, effacement des marques et fausse accusation	A2	C, I	Élevé	F-06, F-15
AC-10	Image piégée (pixel flood, fichier tronqué ou polyglotte)	A1, A3	D	Élevé	F-01, F-06, F-15
AC-11	XSS stocké et injection de requêtes ou de journaux	A1, A3	C, I	Élevé	F-01, F-02, F-07
AC-12	Abus interne : ré-identification et falsification des journaux	A3	C, I	Élevé	F-12, F-13, F-15
AC-13	Compromission des secrets ou de la chaîne d'approvisionnement	A5, A3	C, I	Élevé	F-05, F-06, F-13
AC-14	Déni de service applicatif et indisponibilité à l'entrée	A1, A4	D	Élevé	F-02, F-03, F-09

4.2 Fiches détaillées

Chaque fiche donne le scénario d'attaque, l'impact, le cas d'utilisation de sécurité attendu, les exigences qui l'implémentent et le test d'abus associé.

AC-01 — Scalping automatisé — Élevé

Attaquant : Revendeur disposant de scripts et de comptes multiples. *(profil A1 ; probabilité élevée, impact moyen ; atteinte D, I)*

Scénario : (1) Il crée des comptes en série et fait tourner ses adresses IP. (2) À l'ouverture de la vente, il lance des réservations concurrentes pour épuiser les quotas. (3) Il laisse des réservations non payées bloquer le stock. (4) Il revend les billets hors circuit officiel, à un prix supérieur.

Impact : Stock inaccessible aux acheteurs légitimes, fraude économique, perte de confiance des organisateurs.

Cas d'utilisation de sécurité : Le système ralentit l'automatisation sans bloquer définitivement un utilisateur légitime : quotas par compte et par événement, réservations très courtes, défi adaptatif au-delà d'un seuil de vélocité, alertes et recours.

Exigences : SEC-IA-05, SEC-IA-08, SEC-IA-09, SEC-NR-05, SEC-AU-05, SEC-RD-03, SEC-RD-04.

Test d'abus : Script de 50 comptes et de rotation d'IP : dépassement des seuils → 429 ou défi ; 5e billet refusé ; stock libéré à T+10 min.

AC-02 — Rejeu et double admission d'un billet — Critique

Attaquant : Acheteur malveillant, destinataire d'une capture d'écran ou revendeur du même billet à plusieurs personnes. *(profil A2 ; probabilité élevée, impact élevé ; atteinte I)*

Scénario : (1) Un billet (visuel et QR) est copié ou capturé. (2) Plusieurs porteurs le présentent, parfois en même temps sur deux terminaux, en comptant sur la course entre deux vérifications. (3) Le fraudeur espère être admis deux fois.

Impact : Double présentation, litige sur le détenteur légitime, perte de recettes et d'image.

Cas d'utilisation de sécurité : L'admission dépend uniquement de l'état serveur : une seule transition atomique `ISSUED` → `CONSUMED` ; toute seconde présentation est refusée ; un visuel ou un QR ne suffit jamais à lui seul.

Exigences : SEC-DC-03, SEC-NR-02, SEC-NR-05, SEC-AU-01, SEC-AU-05, SEC-RD-01.

Test d'abus : 100 scans simultanés du même jeton : exactement 1 admission, 99 refus, 100 événements d'audit.

AC-03 — Contrefaçon et altération du billet — Élevé

Attaquant : Faussaire disposant d'une image valide ou d'un modèle de billet. *(profil A2 ; probabilité moyenne, impact élevé ; atteinte I)*

Scénario : (1) Il modifie le siège, la porte ou la date dans l'image, fabrique un QR arbitraire ou insère un faux filigrane ou un faux sceau. (2) Il diffuse ou vend le visuel modifié. (3) Il tente de le faire accepter par un terminal de scan.

Impact : Accès frauduleux, refus d'accès à l'acheteur légitime, litiges.

Cas d'utilisation de sécurité : L'authenticité est décidée par le serveur (jeton opaque, état, signature des claims) ; le sceau fragile révèle toute modification de pixels lors de l'analyse ; un faux sceau ou une fausse marque est rejeté car il dépend d'une clé serveur, de chiffrement et de signature.

Exigences : SEC-DC-01, SEC-DC-02, SEC-DC-03, SEC-DC-04, SEC-DC-12, SEC-NR-01.

Test d'abus : Modification de chaque champ signé → rejet ; sceau forgé sans clé → rejet ; QR inventé → refus au scan.

AC-04 — Accès à l'objet d'autrui (BOLA) — Critique

Attaquant : Acheteur ou organisateur authentifié. *(profil A2, A3 ; probabilité élevée, impact élevé ; atteinte C, I)*

Scénario : (1) En changeant l'identifiant dans `/api/v1/tickets/{id}/transfer`, dans une requête de portefeuille ou dans un lien de téléchargement, il vise le billet d'un autre acheteur. (2) Il lit, télécharge ou transfère ce billet, ou consulte l'événement d'un autre organisateur.

Impact : Vol de billets, divulgation de données d'achat, manipulation d'événements.

Cas d'utilisation de sécurité : Chaque opération vérifie côté serveur que l'appelant est le titulaire ou le propriétaire, quel que soit l'identifiant fourni ; réponse 404 identique pour un objet inexistant ou non autorisé ; identifiants non prédictibles.

Exigences : SEC-AZ-02, SEC-AZ-04, SEC-DC-07, SEC-DC-15.

Test d'abus : L'utilisateur A cible un billet, un téléchargement, un transfert ou un événement de B → 404 indiscernable d'un identifiant inexistant, événement d'audit créé.

AC-05 — Élévation de privilèges et séparation des pouvoirs — Élevé

Attaquant : Utilisateur authentifié (acheteur, agent, auditeur) ou administrateur technique. *(profil A2, A3 ; probabilité moyenne, impact élevé ; atteinte I, C)*

Scénario : (1) Il appelle directement un endpoint oublié sans contrôle d'accès, ou injecte `role`, `status` ou `price` dans un corps JSON (affectation de masse). (2) Il émet, révoque ou modifie un billet, ou, administrateur, réécrit discrètement l'historique de vente ou de scan.

Impact : Altération de preuves métier, fraude, perte d'intégrité.

Cas d'utilisation de sécurité : Refus par défaut sur chaque endpoint ; matrice rôle × action testée automatiquement ; rôle et statut jamais lus depuis le client ; actions privilégiées justifiées et tracées.

Exigences : SEC-IA-02, SEC-IA-07, SEC-IA-08, SEC-AZ-01, SEC-AZ-03, SEC-AZ-04, SEC-AZ-05, SEC-DC-07, SEC-NR-03, SEC-AU-01.

Test d'abus : Chaque couple (rôle, endpoint) non autorisé → 403 ; corps avec champ interdit → 400 ; endpoint sans annotation → build rouge.

AC-06 — Prise de contrôle d'un compte — Élevé

Attaquant : Attaquant externe. *(profil A1 ; probabilité élevée, impact moyen ; atteinte C, I)*

Scénario : (1) Bourrage d'identifiants ou force brute avec rotation d'IP, et énumération des comptes existants. (2) Vol, fixation ou rejeu d'une session. (3) Requête forgée (CSRF) déclenchant un achat ou un transfert depuis le navigateur d'une victime connectée.

Impact : Perte de billets, achats frauduleux, accès à des données personnelles, prise de rôle privilégié.

Cas d'utilisation de sécurité : Hachage Argon2id, verrouillage progressif, réponses indiscernables, session durcie et régénérée, jeton anti-CSRF, TOTP pour les rôles privilégiés.

Exigences : SEC-IA-01, SEC-IA-02, SEC-IA-03, SEC-IA-04, SEC-IA-05, SEC-IA-07, SEC-AZ-08, SEC-DC-10, SEC-DC-11, SEC-AU-01, SEC-AU-05, SEC-RD-03.

Test d'abus : 6e tentative refusée ; cookie rejoué après déconnexion → 401 ; POST cross-origin sans jeton → 403.

AC-07 — Notification de paiement forgée ou rejouée — Élevé

Attaquant : Attaquant externe ou acheteur connaissant l'URL du webhook. *(profil A1, A2 ; probabilité moyenne, impact élevé ; atteinte I)*

Scénario : (1) Il envoie une notification de paiement falsifiée, ou rejoue une notification authentique, ou modifie le montant. (2) Il obtient des billets sans payer ou provoque une double émission.

Impact : Émission frauduleuse, perte financière, comptabilité faussée.

Cas d'utilisation de sécurité : Le webhook est authentifié par signature HMAC du corps brut, borné dans le temps, idempotent, et rapproché de la commande et du montant ; le retour navigateur seul ne vaut jamais paiement.

Exigences : SEC-DC-14, SEC-NR-04.

Test d'abus : Signature invalide, événement rejoué, hors fenêtre ou montant altéré → rejet sans émission.

AC-08 — Terminal de scan ou compte agent compromis — Moyen

Attaquant : Personne ayant volé un terminal ou les identifiants d'un agent. *(profil A4 ; probabilité moyenne, impact moyen ; atteinte C, D)*

Scénario : (1) Elle s'authentifie avec le jeton d'appareil volé. (2) Elle interroge massivement l'endpoint de vérification pour énumérer des jetons valides ou consomme des billets pour priver des détenteurs légitimes. (3) Elle tente d'agir sur un autre événement ou une autre porte.

Impact : Refus d'accès à des détenteurs légitimes, fuite d'information sur l'état des billets.

Cas d'utilisation de sécurité : Jeton d'appareil lié à l'affectation, contrôle ABAC (événement, porte, créneau), limitation de débit par terminal, réponses minimales, alertes et révocation rapide.

Exigences : SEC-IA-06, SEC-AZ-03, SEC-NR-02, SEC-RD-02, SEC-RD-03.

Test d'abus : Jeton d'un autre terminal, événement ou porte → refus ; 61e scan par minute → 429 ; jeton révoqué → 401.

AC-09 — Fuite d'image, effacement des marques et fausse accusation — Élevé

Attaquant : Acheteur malveillant ou tiers disposant d'une image divulguée. *(profil A2 ; probabilité élevée, impact moyen ; atteinte C, I)*

Scénario : (1) L'acheteur publie son billet sur une place de marché. (2) Il tente d'effacer les marques (recompression, redimensionnement, recadrage, bruit) ou republie l'image d'un autre détenteur pour l'incriminer. (3) L'analyse attribue, ou non, la fuite à un exemplaire.

Impact : Fuite non attribuée, ou sanction injustifiée d'un détenteur innocent.

Cas d'utilisation de sécurité : Marquage robuste avec code correcteur et banc d'attaques mesuré ; résultat « non concluant » sous le seuil de confiance ; résolution de l'empreinte sous justification ; corroboration par le journal des téléchargements ; procédure contradictoire.

Exigences : SEC-AZ-06, SEC-DC-05, SEC-DC-06, SEC-DC-15, SEC-AU-05, SEC-AU-07.

Test d'abus : Copie recadrée ou recompressée dans les limites → attribution ; au-delà → « non concluant » ; identifiant forgé → rejeté.

AC-10 — Image piégée (pixel flood, fichier tronqué ou polyglotte) — Élevé

Attaquant : Organisateur ou auditeur malveillant ou compromis ; attaquant disposant d'un compte volé. *(profil A1, A3 ; probabilité moyenne, impact élevé ; atteinte D)*

Scénario : (1) Il fabrique un PNG de quelques kilo-octets déclarant des dizaines de milliers de pixels de côté. (2) Il le téléverse comme fond de billet ou le soumet à l'analyse. (3) Le décodage tente d'allouer l'image complète en mémoire et sature le tas de la JVM.

Impact : Indisponibilité de WildFly, y compris du service de scan à l'entrée.

Cas d'utilisation de sécurité : Dimensions lues avant décodage, plafonds de pixels et de taille, traitement dans une file bornée avec délai maximal, limites mémoire de la JVM et du conteneur, fuzzing du décodeur.

Exigences : SEC-RD-05, SEC-RD-06, SEC-RD-07.

Test d'abus : PNG de 20 000 × 20 000 px, PNG tronqué, polyglotte → rejet en moins de 2 s ; 50 requêtes concurrentes sans `OutOfMemoryError`.

AC-11 — XSS stocké et injection de requêtes ou de journaux — Élevé

Attaquant : Organisateur malveillant ou attaquant externe. *(profil A1, A3 ; probabilité moyenne, impact élevé ; atteinte C, I)*

Scénario : (1) Il saisit un script dans le nom ou la description d'un événement, exécuté dans la session des acheteurs et des agents. (2) Il injecte du JPQL ou du SQL via les paramètres de recherche du catalogue, ou des sauts de ligne (CRLF) dans les valeurs journalisées.

Impact : Vol de session, actions au nom de la victime, lecture ou altération de la base, falsification des journaux.

Cas d'utilisation de sécurité : Validation stricte des entrées, requêtes paramétrées, encodage des sorties, CSP sans script inline, aucun `innerHTML`, cache du service worker limité au shell.

Exigences : SEC-AZ-08, SEC-DC-07, SEC-DC-08, SEC-DC-09, SEC-DC-10, SEC-AU-02, SEC-AU-06, SEC-RD-11.

Test d'abus : Charge XSS stockée et réfléchie non exécutée ; charge d'injection → 400 ou sans effet ; CSP vérifiée en CI.

AC-12 — Abus interne : ré-identification et falsification des journaux — Élevé

Attaquant : Auditeur, administrateur ou organisateur curieux ; compte privilégié compromis. *(profil A3 ; probabilité moyenne, impact élevé ; atteinte C, I)*

Scénario : (1) L'auditeur résout des empreintes sans enquête pour identifier des acheteurs. (2) L'administrateur modifie ou supprime des lignes d'audit, ou consulte directement la table de correspondance, pour masquer une action ou espionner.

Impact : Atteinte à la vie privée, perte de preuve, fausse attribution.

Cas d'utilisation de sécurité : Accès à la table de correspondance sous justification et durée limitée ; droits PostgreSQL en insertion seule sur l'audit ; chaînage des entrées ; séparation des rôles ; alertes.

Exigences : SEC-AZ-06, SEC-AZ-07, SEC-DC-13, SEC-NR-03, SEC-AU-03, SEC-AU-04, SEC-AU-05, SEC-AU-07.

Test d'abus : Résolution sans justification → 403 ; `UPDATE` ou `DELETE` sur l'audit refusés ; rupture de chaîne détectée.

AC-13 — Compromission des secrets ou de la chaîne d'approvisionnement **Élevé**

Attaquant : Attaquant ayant accès au dépôt, à une image Docker, à une sauvegarde, à la configuration WildFly ou à une dépendance npm ou Maven. *(profil A5, A3 ; probabilité moyenne, impact élevé ; atteinte C, I)*

Scénario : (1) Il retrouve la clé privée Ed25519, la clé du sceau ou le secret du webhook dans le dépôt, une couche d'image, un fichier de configuration, une sauvegarde ou les journaux. (2) Ou une dépendance compromise injecte du code dans le bundle de la PWA ou dans le serveur.

Impact : Émission de faux billets valides, forgeage de sceaux et de marques, exécution de code sur le serveur.

Cas d'utilisation de sécurité : Secrets hors dépôt et hors image (credential store Elytron ou secrets Docker), rotation par identifiant de clé, scan de secrets, dépendances verrouillées, SCA et SBOM, console de management non exposée, conteneurs non-root.

Exigences : SEC-AZ-07, SEC-DC-02, SEC-DC-12, SEC-AU-02, SEC-RD-09, SEC-RD-10, SEC-RD-11, SEC-RD-12, SEC-RD-13.

Test d'abus : Scan de secrets, inspection du bundle et des couches d'image ; test de rotation ; pipeline bloqué sur dépendance critique.

AC-14 — Déni de service applicatif et indisponibilité à l'entrée **Élevé**

Attaquant : Attaquant externe ou acheteur automatisé. *(profil A1, A4 ; probabilité élevée, impact moyen ; atteinte D)*

Scénario : (1) Il envoie des rafales de requêtes, des corps volumineux ou des requêtes lentes (slowloris). (2) Il sature le pool de connexions JDBC et les threads. (3) Il provoque des erreurs dans le chemin de validation pour obtenir une admission en mode dégradé.

Impact : Indisponibilité de la réservation et du scan, admissions non vérifiées.

Cas d'utilisation de sécurité : Limites de débit, limites du listener Undertow, pools bornés, échec fermé du scan, procédure manuelle journalisée.

Exigences : SEC-AU-06, SEC-RD-02, SEC-RD-03, SEC-RD-05, SEC-RD-07, SEC-RD-08, SEC-RD-09, SEC-RD-10, SEC-RD-13.

Test d'abus : 1 000 requêtes concurrentes → 429 ou 503 contrôlés, 95e centile du scan $\leq$ 500 ms ; serveur de validation coupé → refus contrôlé.

5 Exigences de sécurité

5.1 Organisation

Les 57 exigences sont classées selon les six types du cours. Chacune est **mesurable**, nommée par sa **couche** de la pile, rattachée à au moins un cas d'abus (colonne *Abus*) et accompagnée de son critère de **vérification**. Le rattachement aux fonctions du cahier des charges et au planning est donné en section 6.

Type d'exigence (cours, chap. 2)	Préfixe	Must	Should	Total	Identifiants
Identification et authentification	SEC-IA	7	2	9	01 à 09
Autorisation (contrôle d'accès)	SEC-AZ	8	0	8	01 à 08
Intégrité et confidentialité des données	SEC-DC	14	1	15	01 à 15
Non-répudiation	SEC-NR	4	1	5	01 à 05
Détection d'intrusions et audit	SEC-AU	5	2	7	01 à 07
Résilience et disponibilité	SEC-RD	11	2	13	01 à 13
Total		**49**	**8**	**57**	

Couche	Technologies du projet	Ce que les exigences y fixent
PWA / SPA	TypeScript, service worker, Web Storage, IndexedDB	CSP, cache limité au shell, absence de secret et de billet dans les stockages.
API REST	Jakarta REST 4.0, CDI, Jakarta Validation 3.1	Refus par défaut, validation des DTO `record`, CSRF, limites de débit, erreurs uniformes.
Jakarta Security	Jakarta Security 4.0 (`HttpAuthenticationMechanism`, `IdentityStore`)	Authentification unique, sessions, rôles, principal.
Persistance	Jakarta Persistence 3.2, PostgreSQL	Requêtes paramétrées, contrôle d'objet dans la requête, transitions atomiques, droits minimaux.
Concurrence	Jakarta Concurrency 3.1, threads virtuels de Java 25	Files et pools bornés, tâches planifiées, sémaphores.
Serveur d'applications	WildFly 42 (Undertow, Elytron)	TLS, limites HTTP, en-têtes de sécurité, pages d'erreur, credential store, console non exposée.
Moteur d'images	`javax.imageio`, module Java autonome	Lecture des dimensions avant décodage, capacité, positions pseudo-aléatoires, marques.
Cryptographie	JCA/JCE (Ed25519, AES-GCM, HKDF, HMAC), Argon2id	Canonicalisation, nonces, rotation de clés.
Déploiement	Docker, GitHub Actions	Durcissement, secrets, analyses SAST/SCA, SBOM, tests sur la pile cible.

5.2 Identification et authentification

Prouver l'identité des acheteurs, des organisateurs, des agents, des auditeurs et des terminaux, sans permettre l'énumération de comptes, le vol de session ni l'auto-attribution de rôle.

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-IA-01 Must	Jakarta Security	Les mots de passe sont hachés en Argon2id par une bibliothèque maintenue (par exemple Bouncy Castle) : mémoire $\geq$ 19 Mio, $\geq$ 2 itérations, parallélisme 1, sel aléatoire unique $\geq$ 16 octets ; longueur $\geq$ 12 caractères ; refus des 10 000 mots de passe les plus courants.	Test d'intégration : paramètres lus dans l'encodage stocké, sel distinct par compte, mot de passe courant refusé.	AC-06
SEC-IA-02 Must	Jakarta Security	Un seul mécanisme d'authentification : un `HttpAuthenticationMechanism` CDI (Jakarta Security 4.0) adossé à un `IdentityStore` ; aucune authentification codée dans les ressources REST, aucun mécanisme BASIC déclaré dans `web.xml` ; principal et rôles fournis par le `SecurityContext`.	Revue de configuration ; requête avec en-tête `Authorization: Basic` → 401.	AC-06 AC-05

suite page suivante

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-IA-03 Must	Servlet / WildFly	Cookie de session `Secure; HttpOnly; SameSite=Lax` (Strict casserait le retour du prestataire de paiement) ; identifiant $\geq$ 128 bits généré par le conteneur ; régénération (`changeSessionId`) à la connexion et au changement de rôle ; inactivité maximale 30 min (15 min pour les rôles privilégiés), durée absolue 8 h ; invalidation serveur à la déconnexion et à la désactivation du compte.	Test navigateur automatisé : attributs présents ; ancien identifiant refusé après connexion ; cookie rejoué après déconnexion $\rightarrow$ 401.	AC-06
SEC-IA-04 Must	API REST	Toute requête modifiant l'état (POST, PUT, PATCH, DELETE) exige un en-tête `X-CSRF-Token` lié à la session et un en-tête `Origin` figurant dans la liste blanche ; seul le webhook de paiement en est exempté (authentifié par SEC-DC-14).	POST cross-origin sans jeton $\rightarrow$ 403 ; jeton d'une autre session $\rightarrow$ 403.	AC-06
SEC-IA-05 Must	API REST	Verrouillage progressif par compte et par IP après 5 échecs en 15 min (1 min, doublé jusqu'à 30 min) ; réponse et temps de réponse indiscernables que le compte existe ou non (hachage factice si le compte est absent).	6e tentative refusée ; mesure des temps sur 200 essais : écart non significatif entre compte existant et inexistant.	AC-06 AC-01
SEC-IA-06 Must	API REST, PostgreSQL	Jeton d'appareil du terminal de scan : $\geq$ 128 bits, stocké haché (SHA-256), lié à une affectation (agent, événement, porte, créneau), révocable, expirant à la fin du créneau.	Jeton d'un autre terminal ou expiré $\rightarrow$ 401 ; jeton révoqué refusé immédiatement.	AC-08
SEC-IA-07 Should	Jakarta Security	Second facteur TOTP (RFC 6238) obligatoire pour les rôles Administrateur, Organisateur et Auditeur ; secret chiffré au repos ; un code n'est accepté qu'une fois dans sa fenêtre.	Connexion sans code valide refusée ; rejeu du même code refusé ; secret absent en clair en base.	AC-06 AC-05
SEC-IA-08 Must	API REST, JPA	Les rôles privilégiés ne s'obtiennent que par création d'un administrateur ; le rôle n'est jamais lu depuis une requête client (l'inscription publique ne crée que des acheteurs) ; l'e-mail est confirmé par un lien à usage unique ($\geq$ 128 bits, 15 min, stocké haché).	Inscription avec `role=ADMIN` dans le corps $\rightarrow$ 400 ; lien rejoué ou expiré refusé.	AC-05 AC-01
SEC-IA-09 Should	API REST	Défi anti-automatisation (CAPTCHA tiers ou preuve de travail) exigé au-delà d'un seuil de vélocité configurable (par défaut : 3 comptes créés ou 10 réservations refusées par IP en 10 min).	Test de charge scripté : au-delà du seuil, requête sans preuve $\rightarrow$ 429 ; parcours légitime inchangé.	AC-01

5.3 Autorisation (contrôle d'accès)

Le contrôle d'accès combine rôle et attributs (cahier des charges, §2.4) ; il est appliqué côté serveur à chaque requête et par défaut en refus.

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-AZ-01 Must	Jakarta Security, REST	Refus par défaut : chaque méthode de ressource REST porte `@RolesAllowed`, `@PermitAll` explicite ou `@DenyAll` (contrôle par rôles activé via `resteasy.role.based.security` ou porté par des EJB de service) ; un test d'architecture fait échouer la CI si une méthode n'est pas annotée.	Test d'architecture par réflexion sur les ressources : endpoint ajouté sans annotation → build rouge ; rôle absent → 403.	AC-05
SEC-AZ-02 Must	API REST, JPA	Un billet n'est lu ou modifié que par son titulaire : le contrôle est fait en couche service à partir du principal authentifié et inscrit dans la requête (`WHERE t.id = :id AND t.holderId = :me`) ; l'identifiant fourni par le client ne détermine jamais seul l'autorisation ; réponse 404 identique pour un objet inexistant ou non autorisé.	Test BOLA : A demande, télécharge ou transfère le billet de B → 404 indiscernable d'un identifiant inexistant.	AC-04
SEC-AZ-03 Must	API REST	Un scan n'est autorisé que si l'agent, l'événement, la porte, le créneau et le terminal correspondent à une affectation active (ABAC) ; la réponse est minimale (admis ou refusé, motif générique), sans donnée personnelle.	Tests combinatoires : chaque attribut invalide → refus ; contenu de la réponse inspecté.	AC-08 AC-05
SEC-AZ-04 Must	API REST, JPA	Un organisateur ne gère que ses événements (`event.ownerId = subject.id` appliqué dans la requête) ; l'événement d'un autre organisateur renvoie 404.	Organisateur A sur un événement de B (lecture, modification, quotas, révocation) → 404.	AC-04 AC-05
SEC-AZ-05 Must	API REST	Séparation des pouvoirs décrite par une matrice rôle × action versionnée : l'auditeur ne peut ni émettre ni révoquer ; l'administrateur ne peut ni modifier un billet consommé ni effacer l'audit ; l'agent ne peut pas rechercher un portefeuille.	Tests RBAC générés depuis la matrice : un cas négatif par couple (rôle, endpoint) refusé.	AC-05
SEC-AZ-06 Must	PostgreSQL, API REST	La table de correspondance empreinte–affectation n'est lisible que par le rôle Auditeur, avec justification (≥ 20 caractères), dossier d'enquête ouvert et accès limité à 24 h ; le compte de base du service courant n'y a aucun droit (rôle de base dédié).	Lecture sans justification → 403 ; requête SQL depuis le compte général → permission refusée.	AC-12 AC-09
SEC-AZ-07 Must	PostgreSQL	Moindre privilège en base : le compte applicatif n'a ni droit DDL ni attribut `SUPERUSER` ; la table d'audit n'accorde que `INSERT` et `SELECT` ; les migrations s'exécutent avec un compte distinct.	`UPDATE` et `DELETE` sur l'audit refusés ; revue des `GRANT` du script de déploiement.	AC-12 AC-13
SEC-AZ-08 Must	API REST, Undertow	CORS en liste blanche d'origines (jamais `*` avec identifiants), méthodes et en-têtes explicitement listés.	Requête depuis une origine tierce : aucun en-tête CORS renvoyé ; contrôle DAST.	AC-06 AC-11

5.4 Intégrité et confidentialité des données

Cette section couvre la signature et le chiffrement du billet, les trois mécanismes de dissimulation, la validation des entrées, la protection du navigateur et la gestion des secrets.

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-DC-01 Must	Crypto (JCA)	Les claims du billet (identifiant, événement, catégorie/porte, rang/siège, créneau, version de format, `kid`) sont sérialisés de façon canonique (JCS, RFC 8785, ou binaire à champs ordonnés) puis signés Ed25519 (`Signature.getInstance('Ed25519')`) ; la version et le `kid` font partie des champs signés.	Test unitaire : altération de chaque champ → échec de vérification ; deux sérialisations équivalentes → mêmes octets.	AC-03
SEC-DC-02 Must	Crypto (JCA)	Le payload du sceau est chiffré en AES-256-GCM, nonce de 96 bits unique par clé (`SecureRandom`), données additionnelles authentifiées = identifiant du billet + version ; erreurs de déchiffrement uniformes.	Bit modifié, étiquette ou AAD altérés → rejet ; 100 000 chiffrements sans nonce dupliqué.	AC-03 AC-13
SEC-DC-03 Must	API REST, PostgreSQL	Le jeton présenté par le QR est opaque ($\geq$ 128 bits aléatoires, base64url), sans donnée personnelle ni séquence ; seul son condensat SHA-256 est stocké ; l'admission dépend uniquement de l'état serveur.	Inspection d'un QR et de la base : aucune donnée personnelle, jeton absent en clair ; une image sans jeton valide ne passe pas.	AC-03 AC-02
SEC-DC-04 Must	Moteur d'images	Les positions LSB du sceau sont tirées d'un générateur pseudo-aléatoire cryptographique initialisé par une clé dérivée en HKDF (secret serveur + identifiant du billet) ; la capacité est contrôlée avant insertion (payload $\leq$ 25 % de la capacité LSB) ; un sceau invalide est distingué d'un sceau absent.	Mauvaise clé → échec d'extraction ; deux billets sur la même image → positions différentes ; capacité dépassée → refus.	AC-03
SEC-DC-05 Must	Moteur d'images, PostgreSQL	L'empreinte est un identifiant pseudonyme $\geq$ 48 bits aléatoires, non séquentiel, unique par contrainte en base, accompagné d'un code correcteur ; aucune donnée personnelle (nom, e-mail, téléphone, document) ni dans l'empreinte ni dans le visuel.	Inspection du visuel et de la base ; doublon → violation de contrainte ; identifiant forgé jamais émis → rejeté.	AC-09
SEC-DC-06 Must	Moteur d'images, CI	Robustesse mesurée par un banc d'attaques automatisé sur un corpus de $\geq$ 50 images (JPEG qualité $\geq$ 70, redimensionnement 75 à 125 %, recadrage $\leq$ 10 %) : objectif de récupération $\geq$ 95 % et faux positifs $\leq$ 1 % ; sous le seuil de confiance, le résultat est « non concluant », jamais une attribution.	Rapport CI archivé des taux de récupération et de faux positifs ; cas sous seuil → « non concluant ».	AC-09
SEC-DC-07 Must	API REST, Validation	Tous les DTO d'entrée sont des `record` validés par Jakarta Validation 3.1 (taille, format, énumération, bornes) ; les propriétés inconnues sont rejetées ; `status`, `price`, `ownerId` et `role` ne sont jamais lus depuis le client.	Corps avec champ interdit ou inconnu → 400 ; tests à base de propriétés sur les bornes.	AC-05 AC-04 AC-11

suite page suivante

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-DC-08 Must	JPA, PostgreSQL	Requêtes JPQL ou Criteria paramétrées uniquement ; aucune concaténation d'entrée utilisateur, y compris dans les requêtes natives et les tris ; les entités JPA ne sont jamais exposées par l'API.	Règle SAST bloquante ; tests d'injection sur la recherche et les filtres du catalogue.	AC-11
SEC-DC-09 Must	Undertow, PWA	Politique CSP posée par un filtre `response-header` Undertow : `default-src 'self'; script-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'none'` (aucun script inline), avec `X-Content-Type-Options: nosniff` et `Referrer-Policy` ; la PWA n'utilise ni `innerHTML` ni `eval` (règle ESLint bloquante) ; toute ressource tierce est en SRI.	Charge XSS stockée dans le nom d'événement non exécutée ; en-têtes vérifiés en CI ; lint rouge sur `innerHTML`.	AC-11
SEC-DC-10 Must	PWA (service worker)	Le service worker ne met en cache que le shell statique versionné ; les réponses `/api/v1/me/*` portent `Cache-Control: no-store` ; aucun jeton ni billet dans `localStorage` ou IndexedDB ; à la déconnexion, `caches.delete` et purge des stockages.	Inspection de Cache Storage, IndexedDB et localStorage après une session complète : aucune donnée de billet ; un second utilisateur du même appareil ne voit rien.	AC-11 AC-06
SEC-DC-11 Must	Elytron, Undertow	HTTPS obligatoire (contexte SSL Elytron ou proxy inverse) : TLS 1.3 de préférence, 1.2 au minimum, suites AEAD ; HSTS ($\geq$ 1 an en production) ; redirection de HTTP vers HTTPS.	Scan TLS en préproduction (testssl.sh) ; HTTP en clair redirigé ; TLS $\leq$ 1.1 refusé.	AC-06
SEC-DC-12 Must	Crypto (JCA), Docker	Clé privée Ed25519, clé AES du sceau, secret HKDF/HMAC du marquage et secret du webhook sont conservés dans un credential store Elytron ou des secrets Docker, injectés au déploiement et versionnés par `kid` avec période de coexistence lors de la rotation ; jamais dans le dépôt, le bundle SPA, les images ou les journaux.	Scan de secrets en CI (gitleaks) ; inspection du bundle et des couches d'image ; test de rotation : anciens billets toujours vérifiables.	AC-13 AC-03
SEC-DC-13 Should	JPA, tâche planifiée	Chaque catégorie de données (compte, transaction, billet, scan, enquête, journaux techniques) a une durée de conservation approuvée et une tâche d'effacement ou d'anonymisation (`ManagedScheduledExecutorService`).	Enregistrement expiré supprimé ou anonymisé selon la politique.	AC-12
SEC-DC-14 Must	API REST	Webhook de paiement : HMAC-SHA256 du corps brut vérifié en temps constant (`MessageDigest.isEqual`), fenêtre de validité de 5 min, idempotence par identifiant d'événement (contrainte d'unicité), rapprochement avec une commande existante et le montant attendu.	Signature invalide, événement rejoué ou hors fenêtre $\rightarrow$ rejet, sans double émission.	AC-07
SEC-DC-15 Must	API REST	Lien de téléchargement du billet : signé (HMAC), usage unique, validité $\leq$ 5 min, sans secret durable ; fichier servi avec `Cache-Control: no-store`.	Lien expiré ou rejoué refusé ; lien d'un autre utilisateur $\rightarrow$ 404.	AC-09 AC-04

5.5 Non-répudiation

Empêcher qu'une entité nie une action : émission, scan, action privilégiée, paiement.

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-NR-01 Must	Crypto (JCA), PostgreSQL	Pour chaque billet émis, claims canoniques, signature et `kid` sont conservés ; la clé publique est publiée avec son `kid` ; la vérification est possible hors ligne par un tiers, avec un script indépendant (JDK ou OpenSSL).	Vérification d'un billet archivé par un script externe, sans accès au serveur.	AC-03
SEC-NR-02 Must	Audit, PostgreSQL	Chaque décision de scan est conservée avec terminal, agent (pseudonyme), horodatage UTC, billet, résultat et motif ; une requête de scan crée exactement un événement.	Série de scans rejouée : un événement par requête ; décisions reconstituables.	AC-02 AC-08
SEC-NR-03 Must	Audit	Les actions privilégiées (émission, révocation, transfert, changement de rôle, résolution d'empreinte, suppression de compte) enregistrent l'auteur, l'horodatage UTC, la justification et les valeurs avant et après (condensées).	Chaque action produit un événement attribuable à un auteur.	AC-05 AC-12
SEC-NR-04 Must	PostgreSQL	Les notifications de paiement sont conservées brutes (corps, signature, identifiant) pour justifier chaque émission de billet.	Chaque billet émis renvoie à une notification ; billet sans notification → anomalie détectée par requête de contrôle.	AC-07
SEC-NR-05 Should	API REST, JPA	Transfert : consentement explicite du titulaire et désignation du nouvel acquéreur journalisés ; révocation de l'ancien billet et émission du nouveau dans une même transaction.	Aucune fenêtre où deux exemplaires actifs coexistent ; consentement présent dans l'audit.	AC-02 AC-01

5.6 Détection d'intrusions et audit

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-AU-01 Must	Audit	Événements d'audit structurés pour : authentification (succès, échec), réservation, paiement, émission, téléchargement, transfert, révocation, scan accepté ou refusé, analyse d'image, résolution d'empreinte, refus d'autorisation, actions d'administration ; champs : horodatage UTC, identifiant de corrélation, acteur pseudonyme, action, objet, résultat.	Scénario complet rejoué : couverture de la liste d'événements par check-list ; un événement par action.	AC-02 AC-05 AC-06
SEC-AU-02 Must	Audit, journalisation	Les journaux ne contiennent ni mot de passe, ni jeton complet, ni clé, ni donnée de carte, ni payload en clair ; les valeurs issues de l'utilisateur sont encodées (CR/LF neutralisés) ; journaux au format JSON structuré.	Recherche automatisée de motifs sensibles ; charge CRLF neutralisée.	AC-13 AC-11

suite page suivante

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-AU-03 Must	PostgreSQL	Table d'audit en insertion seule : `GRANT INSERT, SELECT` uniquement et déclencheur refusant `UPDATE`, `DELETE` et `TRUNCATE` ; export périodique vers un stockage séparé.	`UPDATE` et `DELETE` refusés avec le compte applicatif ; export présent.	AC-12
SEC-AU-04 Should	PostgreSQL	Chaque entrée d'audit inclut le condensat SHA-256 de la précédente ; la chaîne est vérifiée chaque nuit et à la demande ; une rupture déclenche une alerte.	Suppression ou modification d'une ligne → rupture détectée.	AC-12
SEC-AU-05 Should	Audit, API REST	Règles d'alerte visibles de l'administrateur en ≤ 60 s : ≥ 5 échecs d'authentification en 10 min (compte ou IP) ; $\geq$ 3 présentations refusées du même billet en 5 min ; ≥ 10 réservations refusées par quota ou IP en 10 min ; toute analyse d'image ; toute résolution d'empreinte ; toute rupture de chaîne d'audit.	Un scénario par règle ; délai d'alerte mesuré.	AC-01 AC-02 AC-06 AC-09 AC-12
SEC-AU-06 Must	API REST, WildFly	Gestion des erreurs : un `ExceptionMapper<Throwable>` renvoie un corps uniforme (code, identifiant de corrélation), sans trace de pile, version ni requête SQL ; pages d'erreur WildFly personnalisées (`error-page`) ; en-tête `Server` neutralisé.	Entrées invalides et erreurs internes → messages uniformes ; scan des réponses.	AC-11 AC-14
SEC-AU-07 Must	Moteur d'images, Audit	Chaque analyse d'image enregistre l'auditeur, la justification, le condensat SHA-256 de l'image et le résultat (émetteur, empreinte résolue ou non, état du sceau, niveau de confiance) ; une analyse sans justification est refusée.	Analyse sans justification → 400 ; entrée d'audit complète.	AC-09 AC-12

5.7 Résilience et disponibilité

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-RD-01 Must	JPA, PostgreSQL	La consommation est une mise à jour conditionnelle (`UPDATE ... SET status = 'CONSUMED' WHERE id = :id AND status = 'ISSUED'`) dans une transaction, avec contrôle du nombre de lignes modifiées (exactement une) ; `@Version` sur l'entité pour les autres transitions.	100 requêtes simultanées sur le même billet → exactement un succès.	AC-02
SEC-RD-02 Must	API REST, Jakarta Security	Échec fermé : toute erreur ou indisponibilité dans le chemin de vérification (base, signature, état) renvoie un refus ou un état indéterminé, jamais une admission ; le terminal n'admet jamais localement.	Test de chaos : base ou API indisponible → refus contrôlé ; procédure manuelle journalisée.	AC-14 AC-08
SEC-RD-03 Must	API REST	Limites de débit par filtre JAX-RS (seau à jetons) : connexion 10 par minute et par IP, réservation 5 par minute et par compte, scan 60 par minute et par terminal, analyse d'image 5 par minute et par auditeur ; dépassement → 429 avec `Retry-After`.	Test de charge : dépassement → 429 sans dégradation du service.	AC-01 AC-06 AC-14 AC-08

suite page suivante

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-RD-04 Must	JPA, Jakarta Concur.	Quota de 4 billets au plus par compte et par événement (configurable) appliqué dans la transaction de réservation ; une réservation non payée expire en 10 min au plus par une tâche `ManagedScheduledExecutorService` qui libère le stock.	5e billet refusé ; réservation libérée à T+10 min ; réservations concurrentes sans dépassement du stock.	AC-01
SEC-RD-05 Must	Undertow	Limites du listener HTTP : `max-post-size` de 6 Mo (envoi d'image) et plafond applicatif de 64 Ko pour les corps JSON, `max-header-size`, `max-parameters`, délais de lecture (`read-timeout`, `no-request-timeout`) ; dépassement rejeté avant lecture complète.	Requête de 50 Mo → 413 ; connexion lente fermée (slowloris).	AC-14 AC-10
SEC-RD-06 Must	Moteur d'images	Les dimensions sont lues dans l'en-tête (`ImageReader.getWidth` et `getHeight`) avant tout décodage ; rejet au-delà de 16 Mpx ou 5 Mo ; format vérifié par signature PNG et décodage (jamais par extension ou type MIME client) ; métadonnées supprimées.	PNG de 20 000 × 20 000 px, PNG tronqué, polyglotte, fichier renommé : rejet en moins de 2 s sans saturation mémoire ; fuzzing de 10 000 entrées en CI.	AC-10
SEC-RD-07 Must	Jakarta Concur.	Marquage et analyse d'image s'exécutent dans un `ManagedExecutorService` à pool et file bornés (par exemple 4 threads, file de 20), délai maximal 10 s, distinct du traitement d'authentification et de scan ; file pleine → 503 contrôlé ; limites `-Xmx` et mémoire du conteneur définies.	50 analyses concurrentes : aucun `OutOfMemoryError`, 95e centile du scan inchangé ($\leq$ 500 ms).	AC-10 AC-14
SEC-RD-08 Must	WildFly, JPA	Pool de connexions de la datasource borné (`max-pool-size` explicite, `blocking-timeout-wait-millis` $\leq$ 5 000) ; concurrence des threads virtuels limitée par un sémaphore $\leq$ taille du pool ; à saturation, réponses 429 ou 503 contrôlées.	1 000 requêtes concurrentes : réponses 429 ou 503 contrôlées, 95e centile du scan $\leq$ 500 ms sur le trafic admis.	AC-14
SEC-RD-09 Should	PostgreSQL, Docker	Sauvegarde quotidienne chiffrée de la base et du stockage objet ; restauration testée au moins une fois avant livraison ; RPO $\leq$ 24 h et RTO $\leq$ 4 h.	Procédure de restauration exécutée et chronométrée.	AC-14 AC-13
SEC-RD-10 Must	Docker, WildFly	Déploiement durci : interface de management WildFly liée au réseau interne (port 9990 non publié) ; conteneur non-root, système de fichiers en lecture seule hors répertoires nécessaires, images à versions épinglées (condensat) ; seul HTTPS exposé.	Scan de ports du déploiement ; check-list de durcissement ; scan d'image en CI.	AC-13 AC-14
SEC-RD-11 Must	CI/CD	Chaque pull request exécute SAST (SpotBugs avec Find Security Bugs), SCA Java et npm (OWASP Dependency-Check, `npm audit`), tests d'autorisation et recherche de secrets ; dépendances verrouillées (`npm ci`, versions Maven figées) ; une vulnérabilité critique non justifiée bloque la fusion.	Pipeline bloquant avec rapport archivé et seuil de sévérité.	AC-13 AC-11

suite page suivante

ID	Couche	Exigence mesurable	Vérification	Abus
SEC-RD-12 Should	CI/CD	Une SBOM (CycloneDX) est générée à chaque build et analysée.	SBOM archivée ; scan de vulnérabilités réussi.	AC-13
SEC-RD-13 Must	CI/CD, WildFly	Compatibilité de pile : la suite d'intégration s'exécute sur l'image WildFly 42 avec Java 25 (Testcontainers) dès S1 et à chaque pull request ; aucune certification TCK Jakarta EE 11 sur Java 25 n'est revendiquée (cahier des charges, §2.5.4).	Pipeline d'intégration vert sur la pile cible.	AC-14 AC-13

6 Traçabilité et vérification

6.1 Matrice cas d'abus et exigences

Cette matrice réalise la chaîne `AC-xx` → `SEC-xx` → chapitre du cours. Le dernier maillon, le *test*, est le critère de vérification de chaque exigence. La matrice entre fonctions du cahier des charges et exigences figure en section 2.1 ; celle des exigences non fonctionnelles en section 2.3.

Abus	Niveau	Exigences de sécurité (cas d'abus → exigences)	Chapitres
AC-01	Élevé	SEC-IA-05, SEC-IA-08, SEC-IA-09, SEC-NR-05, SEC-AU-05, SEC-RD-03, SEC-RD-04	C3, C4, C5
AC-02	Critique	SEC-DC-03, SEC-NR-02, SEC-NR-05, SEC-AU-01, SEC-AU-05, SEC-RD-01	C3, C5
AC-03	Élevé	SEC-DC-01, SEC-DC-02, SEC-DC-03, SEC-DC-04, SEC-DC-12, SEC-NR-01	C3
AC-04	Critique	SEC-AZ-02, SEC-AZ-04, SEC-DC-07, SEC-DC-15	C3, C4
AC-05	Élevé	SEC-IA-02, SEC-IA-07, SEC-IA-08, SEC-AZ-01, SEC-AZ-03, SEC-AZ-04, SEC-AZ-05, SEC-DC-07, SEC-NR-03, SEC-AU-01	C3, C4, C5
AC-06	Élevé	SEC-IA-01, SEC-IA-02, SEC-IA-03, SEC-IA-04, SEC-IA-05, SEC-IA-07, SEC-AZ-08, SEC-DC-10, SEC-DC-11, SEC-AU-01, SEC-AU-05, SEC-RD-03	C3, C4, C5
AC-07	Élevé	SEC-DC-14, SEC-NR-04	C3, C5
AC-08	Moyen	SEC-IA-06, SEC-AZ-03, SEC-NR-02, SEC-RD-02, SEC-RD-03	C3, C4, C5
AC-09	Élevé	SEC-AZ-06, SEC-DC-05, SEC-DC-06, SEC-DC-15, SEC-AU-05, SEC-AU-07	C3, C4, C5
AC-10	Élevé	SEC-RD-05, SEC-RD-06, SEC-RD-07	C3
AC-11	Élevé	SEC-AZ-08, SEC-DC-07, SEC-DC-08, SEC-DC-09, SEC-DC-10, SEC-AU-02, SEC-AU-06, SEC-RD-11	C3, C5, C6
AC-12	Élevé	SEC-AZ-06, SEC-AZ-07, SEC-DC-13, SEC-NR-03, SEC-AU-03, SEC-AU-04, SEC-AU-05, SEC-AU-07	C4, C5
AC-13	Élevé	SEC-AZ-07, SEC-DC-02, SEC-DC-12, SEC-AU-02, SEC-RD-09, SEC-RD-10, SEC-RD-11, SEC-RD-12, SEC-RD-13	C3, C4, C5, C6, C7
AC-14	Élevé	SEC-AU-06, SEC-RD-02, SEC-RD-03, SEC-RD-05, SEC-RD-07, SEC-RD-08, SEC-RD-09, SEC-RD-10, SEC-RD-13	C3, C5, C7

6.2 Planification par semaine et par chapitre

Les exigences suivent le planning du cahier des charges (§3.2) et l'agenda du cours : chaque exigence est implémentée et testée dans la semaine indiquée.

Sem.	Phases du cahier	Exigences à livrer et à tester dans la semaine
S1	P2 Socle technique, P3 Identité et accès	SEC-IA-01, SEC-IA-02, SEC-IA-03, SEC-IA-04, SEC-IA-05, SEC-IA-08, SEC-AZ-01, SEC-AZ-07, SEC-AZ-08, SEC-DC-07, SEC-DC-08, SEC-DC-09, SEC-DC-11, SEC-AU-06, SEC-RD-05, SEC-RD-11, SEC-RD-13 *(17)*
S2	P4 Billetterie, P5 Preuves visuelles	SEC-AZ-02, SEC-AZ-04, SEC-AZ-05, SEC-DC-01, SEC-DC-02, SEC-DC-03, SEC-DC-04, SEC-DC-05, SEC-DC-06, SEC-DC-10, SEC-DC-12, SEC-DC-14, SEC-DC-15, SEC-NR-01, SEC-NR-04, SEC-RD-03, SEC-RD-04, SEC-RD-06, SEC-RD-07 *(19)*
S3	P6 Contrôle (analyse d'image, transfert) et début de P7	SEC-IA-06, SEC-AZ-03, SEC-AZ-06, SEC-NR-02, SEC-NR-03, SEC-NR-05, SEC-AU-01, SEC-AU-02, SEC-AU-03, SEC-AU-07, SEC-RD-01, SEC-RD-02, SEC-RD-08 *(13)*
S4	Fin de P7 Sécurité, P8 Livraison	SEC-IA-07, SEC-IA-09, SEC-DC-13, SEC-AU-04, SEC-AU-05, SEC-RD-09, SEC-RD-10, SEC-RD-12 *(8)*

Chapitre du cours	S1	S2	S3	S4	Total
3. Confidentialité, intégrité, disponibilité	6	15	3	0	24
4. Authentification, autorisation, informations privées	8	3	3	3	17
5. Journalisation et gestion des erreurs	1	1	7	2	11
6. Tests de sécurité	1	0	0	1	2
7. Déploiement et maintenance	1	0	0	2	3
Total	**17**	**19**	**13**	**8**	**57**

6.3 Stratégie de vérification

— **Tests unitaires** : canonicalisation, signature Ed25519, chiffrement authentifié, transitions d'état.

— **Tests d'intégration** sur WildFly 42 avec Java 25 (Testcontainers) : persistance, transactions, webhook de paiement, transfert, consommation atomique.

— **Tests d'autorisation** générés depuis la matrice rôle × action : un cas négatif par couple, tests d'accès horizontal (BOLA) et vertical.

— **Tests d'abus** : un test automatisé par cas d'abus, nommé par son identifiant (`AbuseCase02Test`).

— **SAST et SCA** : analyse du code Java et des dépendances Maven et npm, recherche de secrets.

— **DAST** : API et SPA déployées, XSS, injections, configuration TLS et en-têtes.

— **Tests de charge et de chaos** : pics de réservation, scans concurrents, indisponibilité de la base.

— **Tests d'images** : fuzzing du décodeur et banc d'attaques sur les marques.

6.4 Portes de sécurité CI/CD

1. **Commit** : formatage, compilation, tests unitaires, détection de secrets.
2. **Pull request** : SAST, SCA, tests d'autorisation, test d'architecture, revue par l'autre membre.

3. **Préproduction** : DAST, tests de charge, tests de restauration, vérification de TLS et des en-têtes.
4. **Production** : approbation manuelle, artefact signé, migration contrôlée, procédure de retour arrière.

Critères bloquants avant mise en production

— Aucun test de double consommation ne produit plus d'une admission.
— Aucun test d'accès horizontal ou vertical non autorisé ne réussit.
— Toute altération d'un champ signé est détectée.
— Aucun secret n'apparaît dans le bundle client, le dépôt, les images ou les journaux.
— Aucune image piégée ne provoque `OutOfMemoryError` ni ne dépasse le délai de traitement.
— Le service n'admet jamais un billet sur la seule base d'une image ou d'un QR non vérifié.
— Les sauvegardes et la restauration sont testées et documentées.

7 Limites, risques résiduels et évolution

7.1 Limites explicites

1. Le filigrane ne rend pas un visuel impossible à modifier ; un filigrane invisible peut être supprimé ou dégradé par des transformations suffisamment agressives.
2. La stéganographie ne rend pas une image impossible à copier et ne remplace ni le chiffrement ni la signature ; le sceau est détruit par toute recompression.
3. L'empreinte attribue un exemplaire distribué ; elle ne prouve pas l'intention ni la culpabilité du titulaire (appareil compromis, partage non autorisé, fuite par un tiers).
4. Aucune décision d'admission ne repose sur les marques : elles sont lues uniquement par le service d'analyse d'image, utilisé par l'auditeur.
5. Un contrôle strictement hors ligne ne peut garantir l'absence de double utilisation ; le mode dégradé est un refus journalisé, jamais une validation locale.
6. Le dispositif anti-scalping réduit les abus mais ne peut garantir l'absence totale de revente illicite ou de comptes frauduleux.

7.2 Risques résiduels

Risque résiduel	Probabilité	Impact	Traitement
Compromission d'un compte acheteur	Moyenne	Moyen	TOTP (Should), alertes, révocation de session, procédure de récupération.
Compromission de la clé de signature	Faible	Critique	Stockage dédié (`SEC-DC-12`), rotation par `kid`, séparation des rôles, plan d'incident.
Fuite volontaire ou involontaire d'un billet	Moyenne	Élevé	Empreinte pseudonyme, accès d'enquête contrôlé (`SEC-AZ-06`), procédure contradictoire.
Effacement agressif des marques	Élevée	Moyen	Seuil de confiance, résultat « non concluant » (`SEC-DC-06`), limites documentées.
Collusion entre détenteurs	Faible	Moyen	Risque accepté : marque dépendante d'une clé par billet.
Indisponibilité du réseau à l'entrée	Moyenne	Élevé	Refus par défaut et procédure manuelle journalisée (`SEC-RD-02`).
Faux positifs de l'anti-fraude	Moyenne	Moyen	Seuils ajustables, revue humaine, contestation.

7.3 Effet de l'ordre de coupe du cahier des charges

En cas de retard, le cahier des charges (§3.5) prévoit un ordre de coupe. Il a l'effet suivant sur les exigences ; le noyau reste intégralement couvert.

Coupe	Exigences différées ou réduites
(1) Export de rapport, second facteur TOTP, récupération de compte	`SEC-IA-07` différée ; les rôles privilégiés restent protégés par `SEC-IA-01`, `SEC-IA-03` et `SEC-IA-05`.
(2) Transfert officiel (`F-08`)	`SEC-NR-05` différée ; `SEC-AZ-02` et `SEC-DC-07` restent valides pour toute future route de transfert.
(3) Anti-fraude réduite à la limitation de débit (`F-11`)	`SEC-AU-05` et `SEC-IA-09` différées ; `SEC-RD-03` et `SEC-RD-04` conservées.
(4) Objectifs de robustesse du filigrane et de l'empreinte limités	`SEC-DC-06` : l'objectif de 95 % est abaissé, la mesure et le résultat « non concluant » sont conservés.

Noyau à ne jamais couper : `SEC-DC-01`, `SEC-DC-02`, `SEC-DC-04`, `SEC-DC-05`, `SEC-RD-01`, `SEC-AZ-01` à `SEC-AZ-05`, `SEC-AU-01`, `SEC-AU-07` (signature canonique, consommation atomique, RBAC/ABAC, journal d'audit, émission avec empreinte et sceau, analyse d'image).

7.4 Gestion des exigences et évolution

Toute modification du document passe par une issue GitHub étiquetée `requirement-change`, qui précise la justification et l'impact sur les cas d'abus, les exigences, les fonctions et les tests, puis par une pull request relue par l'autre membre de l'équipe. Chaque changement est daté dans l'historique des versions et le PDF est régénéré sous `/docs`. Les identifiants ne sont jamais réutilisés : une exigence abandonnée est marquée « retirée ». Les tickets sont étiquetés `abuse-case`, `security-requirement` et `feature` ; chaque exigence `SEC-xx` est référencée dans le code et dans les tests.

Jalon du cours	Évolution attendue
Ch. 3 Confidentialité, intégrité, disponibilité	Paramètres cryptographiques définitifs ; limites de décodage d'images ajustées ; exigences `SEC-DC` et `SEC-RD` affinées.
Ch. 4 Authentification, autorisation, informations privées	Politique de sessions et de mots de passe ; matrice rôle × action finale ; revue de la minimisation des données.
Ch. 5 Journalisation et gestion des erreurs	Liste définitive des événements d'audit et du format d'erreur (`SEC-AU`).
Ch. 6 Tests de sécurité	Résultats, cas d'abus découverts, niveaux révisés ; exigences *Should* promues en *Must* si possible.
Ch. 7 Déploiement et maintenance	Durcissement, secrets, suivi des dépendances, sauvegardes.

Références

Références

[1] Eclipse Foundation, *Jakarta EE Platform 11*. `https://jakarta.ee/specifications/platform/11/`

[2] Eclipse Foundation, *Jakarta Security 4.0*. `https://jakarta.ee/specifications/security/4.0/`

[3] WildFly, *Documentation de WildFly* (sous-systèmes Elytron et Undertow). `https://docs.wildfly.org/`

[4] Oracle, *Java 25 Documentation — Virtual Threads*. `https://docs.oracle.com/en/java/javase/25/core/virtual-threads.html`

[5] IETF, *RFC 8032 — Edwards-Curve Digital Signature Algorithm (EdDSA)*. `https://www.rfc-editor.org/rfc/rfc8032`

[6] IETF, *RFC 8785 — JSON Canonicalization Scheme (JCS)*. `https://www.rfc-editor.org/rfc/rfc8785`

[7] IETF, *RFC 9106 — Argon2*. `https://www.rfc-editor.org/rfc/rfc9106`

[8] IETF, *RFC 5869 — HKDF*. `https://www.rfc-editor.org/rfc/rfc5869`

[9] IETF, *RFC 6238 — TOTP*. `https://www.rfc-editor.org/rfc/rfc6238`

[10] NIST, *SP 800-38D — Galois/Counter Mode (GCM)*. `https://csrc.nist.gov/pubs/sp/800/38/d/final`

[11] OWASP, *API Security Top 10 (2023)*, API1 : Broken Object Level Authorization. `https://owasp.org/API-Security/`

[12] Union européenne, *Règlement (UE) 2016/679 (RGPD)*, articles 5, 25 et 32. `https://eur-lex.europa.eu/eli/reg/2016/679/oj`

Annexe A — Glossaire

ABAC Attribute-Based Access Control : contrôle d'accès fondé sur des attributs (événement, porte, créneau, propriétaire).

AC Cas d'abus (*abuse case*) : cas d'utilisation inversé décrivant ce qu'un attaquant tente de faire.

BOLA Broken Object Level Authorization : accès à l'objet d'un autre utilisateur en modifiant un identifiant.

C-I-D Confidentialité, intégrité, disponibilité.

CSP Content Security Policy.

CSRF Cross-Site Request Forgery.

HKDF Fonction de dérivation de clés fondée sur HMAC (RFC 5869).

JCS JSON Canonicalization Scheme (RFC 8785) : sérialisation canonique avant signature.

LSB Bit de poids faible, utilisé par la stéganographie.

RBAC Role-Based Access Control.

SAST, SCA, DAST Analyse statique du code, analyse des dépendances, analyse dynamique de l'application déployée.

SBOM Software Bill of Materials : inventaire des composants logiciels.

SEC Préfixe des exigences de sécurité de Tessera.

SRE Security Requirements Engineering : ingénierie des exigences de sécurité.

SRI Subresource Integrity.

TOTP Time-based One-Time Password (RFC 6238).

XSS Cross-Site Scripting.